

Infrastructure & Dependency Management Policy

Owner: Transformative Leadership Lab LLC · **Applies to:** Meeting Cost Meter (Zoom App)

Contact: thomas+mcsupport@txl-lab.com · **Effective:** 1 June 2026 · **Review:** annually or on material change

Dependencies

- **Package manager:** npm, with a committed `package-lock.json` for reproducible installs.
- **Minimal surface:** runtime dependencies are deliberately small — the server runs on Express plus Node's built-in modules; the client is React + Vite + the Zoom Apps SDK.
- **Automated updates:** Dependabot (`.github/dependabot.yml`) opens weekly PRs for npm and GitHub-Actions updates; GitHub dependency alerts are enabled.
- **Vulnerable dependencies:** security-relevant updates are prioritized and remediated per `vulnerability-management.md` . Every update PR goes through the standard SSDLC merge gate (review + all required status checks) before merge — see `ssdlc.md` § Merge control.
- **Supply chain:** a pre-commit secret-scanning hook prevents credential leakage; dependencies are pinned via the lockfile; the Node engine is pinned (`engines.node >=22`).

Infrastructure

- **Hosting:** Railway runs the Node/Express service. Deploys are automatic on merge to `main` and gated by a `/api/health` check.
- **Source & CI:** GitHub hosts the repository and runs CI on every push/PR to `main` — CodeQL (SAST) and a test/build workflow (`npm test` + `npm run build`). `main` is a protected branch whose merge gate (required checks, PR, no force-push/deletion) is defined in `SSDLC` § Merge control.
- **Configuration & secrets:** all environment-specific configuration and secrets are set as environment variables per environment, never committed to the repository.
- **Runtime hardening:** HTTPS/HSTS and security headers on all responses; least-privilege credentials.

Change management

Infrastructure and dependency changes follow the same SSDLC as application code: a reviewed pull request, all required status checks passing, and merge to the protected `main` branch before deploy (see `ssdlc.md` § Merge control).

Vendors

GitHub (source/CI), Railway (hosting/storage), Zoom (platform). No other infrastructure providers or third-party data processors.